

Security Guide Evolution 2

Contents:

- [Qualys SSL Server Test Summary](#)
- [Audit Logging](#)
- [Session Timeouts](#)
- [MFA with Google Authenticator app](#)
- [Qualys SSL Server Full Report](#)
- [File Upload Security](#)
- [Server Side Time Checks](#)

Qualys SSL Server Test

Summary of SSL Security Report for abroad.colab.duke.edu

Overall Rating: **A**

The website abroad.colab.duke.edu received an **A** rating on the SSL security test, indicating strong encryption and compliance with modern security standards. No part of the code base was changed in order to receive this rating.

Security Strengths

- **TLS 1.3 & TLS 1.2 Support** – The server supports **TLS 1.3**, the most secure version, and **TLS 1.2**, ensuring strong encryption and compatibility.
- **Strong Cipher Suites** – Uses robust ciphers, including AES-GCM and CHACHA20, with Forward Secrecy (FS) enabled for most browsers.
- **No Vulnerable Protocols** – SSL 2, SSL 3, TLS 1.0, and TLS 1.1 are disabled, mitigating older exploits like **POODLE** and **BEAST**.
- **No Known Critical Vulnerabilities** – The server is **not vulnerable** to **Heartbleed**, **ROBOT**, **POODLE**, and **Ticketbleed** attacks.
- **RSA 2048-bit Key & SHA256 Signature** – Uses a **strong 2048-bit RSA certificate with SHA256 hashing**, ensuring certificate integrity.
- **Certificate Trusted by Major Platforms** – The SSL certificate is **trusted by all major browsers and operating systems**.

Security Weaknesses

- **Short Certificate Validity** – The certificate expires in **1 month and 21 days**, requiring renewal soon.
- **No HTTP Strict Transport Security (HSTS)** – **HSTS is not enabled**, which means browsers may allow users to access the site over **HTTP**, making it vulnerable to **man-in-the-middle (MITM) attacks**.
- **No OCSP Must Staple** – The server does not enforce **OCSP stapling**, which could **slow down certificate revocation checks**.
- **No DNS CAA Records** – **Certificate Authority Authorization (CAA) records are missing**, meaning unauthorized certificate issuers could potentially issue a certificate for

this domain.

- **No Public Key Pinning (HPKP)** – The server does not implement **HTTP Public Key Pinning (HPKP)**, which could **prevent certificate forgery attacks**.
- **Session Resumption (Tickets) Not Supported** – This could lead to **slightly slower** SSL handshakes and increased server load.

Audit Logging

Summary of Middleware File: AuditLoggingMiddleware

This middleware logs user activity and requests to an **audit.log** file, ensuring security and traceability. It performs the following key functions:

- **Logging Requests**
 - Captures HTTP method, path, user (if authenticated), IP address, headers, and body (for certain methods).
 - Masks sensitive fields like passwords and tokens.
- **Setting Server permissions**
 - Command line permissions on server

```
sudo chown www-data:www-data /home/jc870/abroad-hub/backend/backend/audit.log
```

- This grants ownership of the audit.log file to the www-data user and group. Meaning that the Nginx process, which runs as the www-data user, now has permission to read from and write to this log file.
- **Request Processing and Logging**
 - Intercepts **POST, PUT, DELETE, PATCH** requests, logging request data and user details.
 - Detects login and SSO-related requests for additional logging.
- **Extracting Client Information**
 - Retrieves the **real client IP** (even behind proxies).
 - Safely parses request data, handling JSON and form-encoded inputs.
 - Identifies the username from request body for login attempts.

This middleware enhances **security, auditing, and compliance**.

Session Timeouts

Summary of Session Timeouts Implementation

The session timeout mechanism is designed to enhance security by enforcing both inactivity and hard session expiration limits through JWT token configurations and frontend session monitoring. This prevents unauthorized and indefinite access.

1. Backend (Django settings.py - JWT Configuration)

- **Inactivity Timeout:** The `ACCESS_TOKEN_LIFETIME` is set to **15 minutes**, meaning a user must remain active to maintain their session.
- **Hard Expiration:** The `REFRESH_TOKEN_LIFETIME` is **24 hours**, ensuring that a session cannot extend beyond a full day, even if the user remains active.
- **Token Rotation Disabled:** `ROTATE_REFRESH_TOKENS` is set to `False`, preventing refresh token extension beyond the 24-hour limit.
- **Blacklisting Old Tokens:** `BLACKLIST_AFTER_ROTATION` is set to `True`, ensuring that old refresh tokens are revoked to prevent replay attacks.

2. Frontend (ProtectedRoute.tsx - React Implementation)

- **Session Monitoring:** The frontend tracks the last activity and login time.
- **Automatic Logout:** If a user exceeds **15 minutes of inactivity** or the session exceeds **24 hours**, they are logged out and redirected to the login page.
- **User Notification:** Users are alerted when their session expires due to inactivity or duration limits.

MFA with Google Authenticator App

The MFA (Multi-Factor Authentication) security feature for local users adds an extra layer of protection by requiring an OTP (One-Time Password) verification from the Google Authenticator app during login, in addition to the usual credentials. The key components are:

Backend

1. **User Configuration:** Each user has a `use_mfa` boolean field that determines if MFA is enabled. MFA is only required if the user is not an SSO (Single Sign-On) user.
2. **APIs:**
 - `api/mfa-settings/`: Updates the user's `use_mfa` field when enabling or disabling MFA in their profile settings.
 - `api/verify-otp/`: Verifies the entered OTP against the session's stored OTP.
 - `api/token/`: A custom token view that checks whether MFA is enabled (`use_mfa` is true) and returns OTP url if required.
3. **Middleware:**
 - `django_otp.middleware.OTPMiddleware` ensures OTP validation is handled during login requests.
 - Email configuration sends the OTP to the user's email.
4. **Views:**
 - `CustomTokenObtainPairView`: Customizes the token generation process to check for MFA requirements. If MFA is enabled, it generates and sends an OTP url to the user.
 - `VerifyOTPView`: Handles OTP validation. Upon successful verification, the system generates and returns JWT tokens (access and refresh).
 - `UpdateMFASettingsView`: Allows users to enable or disable MFA, ensuring SSO users cannot modify MFA settings.

Frontend

1. **MFA Settings Component:** Accessible from the user profile, this component allows users to enable or disable MFA. It takes the current user's MFA setting and the route to navigate after submission.
2. **OTP Verification Component:** Displays a form for the user to enter the 6-digit OTP and QR code to scan with the authenticator app. Once you scan the QR code once, your account is registered with the Authenticator app and you no longer have to re-scan the QR, just enter the current 6 digit OTP the app shows on your next login.

Appendix of Full Report

2/27/25, 9:18 AM SSL Server Test: abroad.colab.duke.edu (Powered by Qualys SSL Labs)



Home Projects Qualys Free Trial Contact You are here: [Home](#) > [Projects](#) > [SSL](#)

SSL Report: abroad.colab.duke.edu (67.159.77.223)

Assessed on: Thu, 27 Feb 2025 14:13:53 UTC | [Hide](#) | [Clear cache](#)

[Scan Another »](#)

Summary

Overall Rating

A

Certificate

Protocol Support

Key Exchange

Cipher Strength

0

20

40

60

80

100

Visit our [documentation page](#) for more information, configuration guides, and books. Known issues are documented [here](#).

This server supports TLS 1.3.

This server supports TLS 1.3.

Certificate #1: RSA 2048 bits (SHA256withRSA)



Server Key and Certificate #1

Subject

Fingerprint SHA256:

Common names

Alternative names

Serial Number

Valid from

Valid until

Key

Weak key

Issuer

Signature algorithm

Extended Validation

Certificate Transparency

OCSP Must Staple

Revocation information

Revocation status

DNS CAA

Trusted

abroad.colab.duke.edu

d66ed84b0093e67b06e149bfod51ea6db850162da0e863e76c85de0a8f06b236

Pin SHA256: wdj844qb1b5eQetnBXkgMpZn0ERVPT0PqkA4aQxK13E=

http://r10.i.lencr.org/

SHA256withRSA

No

Yes (certificate)

No

OCSP

Good (not revoked)

No (more info)

Yes

Mozilla

Apple

Android

Java

Windows



Additional Certificates (if supplied)

Certificates provided 2 (2566 bytes)
Chain issues None

#2

https://www.ssllabs.com/ssltest/analyze.html?d=abroad.colab.duke.edu 1/4

2/27/25, 9:18 AM SSL Server Test: abroad.colab.duke.edu (Powered by Qualys SSL Labs) Additional Certificates (if supplied)

Subject

R10

9d7c3f1aa6ad2b2ec0d5cf1e246f8d9ae6cbc9fd0755ad37bb974b1f2fb603f3
Pin SHA256: K7rZOrXhknsEhUH8nLL4MZejuUulvOlr6tCa0rbo=

Fingerprint SHA256:

Valid until Fri, 12 Mar 2027 23:59:59 UTC (expires in 2 years)

Key RSA 2048 bits (e 65537)

Issuer ISRG Root X1

Signature algorithm SHA256withRSA



Certification Paths [Click here to expand](#)

Configuration



Protocols

TLS 1.3 Yes
TLS 1.2 Yes
TLS 1.1 No
TLS 1.0 No
SSL 3 No
SSL 2 No



Cipher Suites

TLS 1.3 (server has no preference) [Expand](#)

TLS_AES_128_GCM_SHA256 (0x1301) ECDH x25519 (eq. 3072 bits RSA) FS 128
TLS_AES_256_GCM_SHA384 (0x1302) ECDH x25519 (eq. 3072 bits RSA) FS 256
TLS_CHACHA20_POLY1305_SHA256 (0x1303) ECDH x25519 (eq. 3072 bits RSA) FS 256

TLS 1.2 (server has no preference) [Expand](#)

TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e) DH 2048 bits FS 128
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f) ECDH secp521r1 (eq. 15360 bits RSA) FS 128
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f) DH 2048 bits FS 256
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030) ECDH secp521r1 (eq. 15360 bits RSA) FS 256
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8) ECDH secp521r1 (eq. 15360 bits RSA) FS 256



Handshake Simulation

[Android 4.4.2](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS
[Android 5.0.0](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp521r1 FS
[Android 6.0](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp256r1 FS
[Android 7.0](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[Android 8.0](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[Android 8.1](#) - TLS 1.3 TLS_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[Android 9.0](#) - TLS 1.3 TLS_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[BingPreview Jan 2015](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS
[Chrome 49 / XP SP3](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp256r1 FS
[Chrome 69 / Win 7 R](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH x25519 FS
[Chrome 70 / Win 10](#) - TLS 1.3 TLS_AES_128_GCM_SHA256 ECDH x25519 FS
[Chrome 80 / Win 10 R](#) - TLS 1.3 TLS_AES_128_GCM_SHA256 ECDH x25519 FS
[Firefox 31.3.0 ESR / Win 7](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp256r1 FS
[Firefox 47 / Win 7 R](#) RSA 2048 (SHA256) TLS 1.2 > [http/1.1](#) TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp256r1 FS

https://www.ssllabs.com/ssltest/analyze.html?d=abroad.colab.duke.edu 2/4

[Firefox 49 / XP SP3](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH secp256r1 FS
[Firefox 62 / Win 7](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH x25519 FS
[Firefox 73 / Win 10](#) R - TLS 1.3 TLS_AES_128_GCM_SHA256 ECDH x25519 FS
[Googlebot Feb 2018](#) RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 ECDH x25519 FS
[IE 11 / Win 7](#) R RSA 2048 (SHA256) TLS 1.2 TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 DH 2048 FS
[IE 11 / Win 8.1](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 DH 2048 FS
[IE 11 / Win Phone 8.1](#) R Server sent fatal alert: handshake_failure
[IE 11 / Win Phone 8.1 Update](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 DH 2048 FS
[IE 11 / Win 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Edge 15 / Win 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
[Edge 16 / Win 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
[Edge 18 / Win 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
[Edge 13 / Win Phone 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Java 8u161](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Java 11.0.3](#) - TLS 1.3 TLS_AES_128_GCM_SHA256 ECDH secp256r1 FS
[Java 12.0.1](#) - TLS 1.3 TLS_AES_128_GCM_SHA256 ECDH secp256r1 FS
[OpenSSL 1.0.1j](#) R RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS
[OpenSSL 1.0.2s](#) R RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[OpenSSL 1.1.0k](#) R RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH x25519 FS
[OpenSSL 1.1.1g](#) R - TLS 1.3 TLS_AES_256_GCM_SHA384 ECDH x25519 FS
[Safari 6 / iOS 6.0.1](#) Server sent fatal alert: handshake_failure
[Safari 7 / iOS 7.1](#) R Server sent fatal alert: handshake_failure
[Safari 7 / OS X 10.9](#) R Server sent fatal alert: handshake_failure
[Safari 8 / iOS 8.4](#) R Server sent fatal alert: handshake_failure
[Safari 8 / OS X 10.10](#) R Server sent fatal alert: handshake_failure
[Safari 9 / iOS 9](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Safari 9 / OS X 10.11](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Safari 10 / iOS 10](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Safari 10 / OS X 10.12](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Safari 12.1.2 / MacOS 10.14.6](#)
[Beta](#) R - TLS 1.3 TLS_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[Safari 12.1.1 / iOS 12.3.1](#) R - TLS 1.3 TLS_CHACHA20_POLY1305_SHA256 ECDH x25519 FS
[Apple ATS 9 / iOS 9](#) R RSA 2048 (SHA256) TLS 1.2 > http/1.1 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp256r1 FS
[Yahoo Slurp Jan 2015](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp384r1 FS
[YandexBot Jan 2015](#) RSA 2048 (SHA256) TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 ECDH secp521r1 FS

Not simulated clients (Protocol mismatch) 

[Click here to expand](#)

- (1) Clients that do not support Forward Secrecy (FS) are excluded when determining support for it.
(2) No support for virtual SSL hosting (SNI). Connects to the default site if the server uses SNI.
(3) Only first connection attempt simulated. Browsers sometimes retry with a lower protocol version.
(R) Denotes a reference browser or client, with which we expect better effective security.
(All) We use defaults, but some platforms do not use their best protocols and features (e.g., Java 6 & 7, older IE).
(All) Certificate trust is not checked in handshake simulation, we only perform TLS handshake.



Protocol Details

Secure Renegotiation Supported

Secure Client-Initiated Renegotiation No

Insecure Client-Initiated Renegotiation No

BEAST attack Mitigated server-side ([more info](#))

POODLE (SSLv3) No, SSL 3 not supported ([more info](#))

POODLE (TLS) No ([more info](#))

Zombie POODLE No ([more info](#))

<https://www.ssllabs.com/ssltest/analyze.html?d=abroad.colab.duke.edu> 3/4

GOLDENDOODLE No ([more info](#))

OpenSSL 0-Length No ([more info](#))

Sleeping POODLE No ([more info](#))

Downgrade attack prevention Yes, TLS_FALLBACK_SCSV supported ([more info](#))

SSL/TLS compression No

RC4 No

Heartbeat (extension) No

Heartbleed (vulnerability) No ([more info](#))

Ticketbleed (vulnerability) No ([more info](#))
OpenSSL CCS vuln. (CVE-2014-0224) No ([more info](#))
OpenSSL Padding Oracle vuln.
(CVE-2016-2107) No ([more info](#))
ROBOT (vulnerability) No ([more info](#))
Forward Secrecy Yes (with most browsers) ROBUST ([more info](#))
ALPN Yes [http/1.1](#)
NPN Yes [http/1.1](#)
Session resumption (caching) Yes
Session resumption (tickets) No
OCSP stapling No
Strict Transport Security (HSTS) No
HSTS Preloading Not in: Chrome Edge Firefox IE
Public Key Pinning (HPKP) No ([more info](#))
Public Key Pinning Report-Only No
Public Key Pinning (Static) No ([more info](#))
Long handshake intolerance No
TLS extension intolerance No
TLS version intolerance No
Incorrect SNI alerts No
Uses common DH primes No
DH public server param (Ys) reuse No
ECDH public server param reuse No
Supported Named Groups secp256r1, secp384r1, secp521r1, x25519, x448 (Server has no preference)
SSL 2 handshake compatibility No
0-RTT enabled No



HTTP Requests

1 <https://abroad.colab.duke.edu/> (HTTP/1.1 200 OK)



Miscellaneous

Test date Thu, 27 Feb 2025 14:12:48 UTC
Test duration 64.526 seconds
HTTP status code 200
HTTP server signature nginx/1.18.0 (Ubuntu)
Server hostname vcm-45223.vm.duke.edu

SSL Report v2.3.1

Copyright © 2009-2025 [Qualys, Inc.](#). All Rights Reserved. [Privacy Policy](#). [Terms and Conditions](#). [Try Qualys for free!](#) Experience the award-winning [Qualys Cloud Platform](#) and the entire collection of [Qualys Cloud Apps](#), including [certificate security](#) solutions.

File Upload Security

Summary of our file upload security.

We use both client and server side checks for file type, size, and content (only server-side) to ensure that users don't upload malicious content.

- **Client Side**

- Checks that the file type is pdf using MIME type (application/pdf) and limits file selection for user to pdf files
- Limits file size to 10MB before uploading to server
- Ensures correct permissions so users can only upload to the correct application.
- Sanitizes file urls for viewing documents to prevent path traversal from malicious users

- **Server Side**

- File type checking
 - Validates extension (.pdf)
 - Checks MIME type (application/pdf)
 - Examines the header bytes to confirm it starts with PDF signature (%PDF-)
- Document Size Restriction to 10MB
- Application level permissions check making sure only the correct users can access

Server Side Time Checks

- Added server side time checks for trying to submit applications past the deadline.
 - Before, since we were only checking on the client side, users could change their clock locally and the request would go through
 - Now the time check happens on the server side with the server clock before creation.